Риск-ландшафт Linux-инфраструктуры

Разобранный до абзацев каркас научно-исследовательской работы, которая затем без переписывания становится первой главой диплома. Сделан на теме Перушкина как на самой обозримой из четырёх; в конце — таблица переноса на Kubernetes, CI/CD и систему управления доступом.

> ТЕМА
>
> Разработка интеллектуальной системы оценки киберрисков серверной инфраструктуры Linux в условиях эксплуатации ошибок конфигурирования сервисов
>
> Перушкин · рук. Чопоров О. Н. · методика Остапенко А. Г.

00 Почему это вообще собирается в одну работу

Схема не выдуманная — она уже отработана на курсе ИБ-201. Косухин писал НИР по производственной практике на тему «Организационно-правовое регулирование рисков успешности атак типа *Проверка эхо-запроса ICMP*», а через год его ВКР называлась «Оценка и регулирование рисков успешности реализации в АИС кибератак класса *Обнаружение хоста*». Куски НИР разошлись по диплому так:

Таблица 0.1 — Фактический перенос НИР в ВКР (прецедент Косухина Б. Р., ИБ-201)

РАЗДЕЛ НИР	КУДА ВОШЁЛ В ВКР
1. Базы знаний по атакам, использующим метод ICMP Echo Request 1.1 сценарии реализации · 1.2 база знаний об уязвимостях · 1.2.2 риск-ландшафт	**Глава 1.** Анализ баз данных угроз ИБ и риск-калькуляторов 1.1 CVE, NVD, CAPEC, БДУ ФСТЭК, ATT&CK · 1.2 EPSS, CVSS 3.1, CVSS 4.0, OWASP
2. Частная политика противодействия регламенты выявления · реагирования · ликвидации последствий	**Глава 4.** Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев
3. Частные инструкции для противодействия атаке	туда же, в главу 4

Вывод для вас: НИР пишется **шире**, чем требуется первой главе. Аналитическая половина уходит в главу 1, регламентная — в последнюю. За один документ закрываются оба конца диплома, а между ними остаётся только собственно исследование.

ПРАВКА РУК. В заметках к той же НИР руководитель оставил два указания: «главы как по графику, только без политики противодействия» и «риск-ландшафт после базы знаний отдельной подглавой». Второе учтено ниже — риск-ландшафт вынесен в самостоятельный раздел 3, а не спрятан внутрь анализа уязвимостей.

01 Введение: готовый текст по шаблону кафедры

Порядок элементов здесь не произвольный — он взят из статьи Остапенко и соблюдается во всех двадцати работах ИБ-201. Главное правило: **сколько противоречий, столько задач, столько результатов на защиту, столько пунктов новизны,**

теоретической значимости и практической ценности. Ниже — четыре противоречия и, соответственно, четвёрки везде. Жёлтым помечено то, что вы подставляете своей рукой.

1.1 Актуальность

ЧЕРНОВИК ТЕКСТА

Серверная инфраструктура на базе операционных систем семейства Linux составляет основу вычислительных мощностей государственных и коммерческих организаций Российской Федерации: на неё приходится `доля рынка серверных ОС, % — статистика за 2022–2025`, а темпы перехода на отечественные дистрибутивы после `год` составили `%`.

При этом смещается сам характер угроз. Если традиционно защищённость сервера отождествлялась с отсутствием непропатченных уязвимостей программного кода, то по данным `источник: Positive Technologies / Solar / Verizon DBIR` за 2024 год `%` успешных проникновений в инфраструктуру не эксплуатировали ни одной уязвимости с CVE-идентификатором, а использовали **ошибки конфигурирования сервисов**: разрешённый вход суперпользователя по SSH, парольную аутентификацию вместо ключевой, избыточные права `sudo`, файлы с установленным битом SUID, доступный из контейнера сокет `docker.sock`, отключённую подсистему аудита.

Значимость этого класса недостатков закреплена нормативно: ГОСТ Р 56546 выделяет уязвимости конфигурации в самостоятельный класс наряду с уязвимостями кода, а Методика оценки угроз безопасности информации ФСТЭК России требует учитывать их при определении актуальных угроз. Однако инструментальная и методическая база отстаёт: `3–4 предложения о том, что существующие средства дают проверку соответствия, а не оценку риска`.

Рост доли конфигурационных ошибок в структуре успешных атак, их нормативная значимость и отсутствие методик, переводящих факт несоответствия в количественную меру риска, свидетельствуют о том, что задача оценки и регулирования киберрисков серверной инфраструктуры Linux сохраняет и усиливает свою актуальность.

ТРЕБОВАНИЕ

Статистика нужна **в динамике** и **не только отечественная** — это явное требование методики. Один показатель за 2024 год не принимается; нужен ряд за три-четыре года, показывающий тенденцию, и хотя бы один зарубежный источник рядом с отечественным.

1.2 Объект, предмет, цель

ЧЕРНОВИК ТЕКСТА

Объектом исследования выступает серверная инфраструктура на базе операционных систем семейства Linux, подверженная кибератакам, эксплуатирующим ошибки конфигурирования сервисов.

Предметом исследования являются процессы оценки и регулирования рисков успешности реализации кибератак, эксплуатирующих ошибки конфигурирования сервисов Linux, включающие установление соответствия между конфигурационными недостатками и техниками их эксплуатации, сценарное моделирование, количественную оценку рисков и выработку мер их снижения.

Цель исследования состоит в повышении защищённости серверной инфраструктуры Linux от кибератак, эксплуатирующих ошибки конфигурирования сервисов, за счёт создания интеллектуальной системы оценки и регулирования киберрисков.

Обе формулировки — «оценка и регулирование рисков» в предмете и «повышение защищённости» в цели — заданы методикой дословно. Своими словами их пересказывать не нужно: это ровно тот случай, когда совпадение с шаблоном считается достоинством.

1.3 Противоречия

Это несущая конструкция всего введения. Каждое противоречие строится по одной схеме: *между необходимостью X и невозможностью/ограниченностью Y у существующих средств*. Четыре штуки — рабочий минимум.

ЧЕРНОВИК ТЕКСТА

Исследование аналогов показало наличие ряда противоречий между:

- необходимостью учёта ошибок конфигурирования сервисов при оценке киберрисков серверной инфраструктуры и ориентированностью действующих баз данных уязвимостей (CVE, NVD, БДУ ФСТЭК России) преимущественно на уязвимости программного кода, вследствие чего конфигурационный недостаток не получает идентификатора и выпадает из риск-анализа;
- потребностью в количественной оценке критичности ошибок конфигурирования и возможностями существующих риск-калькуляторов CVSS 3.1, CVSS 4.0 и EPSS, рассчитанных на уязвимости, обладающие CVE-идентификатором и накопленной статистикой эксплуатации;
- необходимостью учёта взаимного влияния конфигурационных недостатков, образующих цепочки повышения привилегий и перемещения внутри периметра, и единичным, пообъектным характером проверок существующих средств анализа защищённости;
- потребностью в непрерывной переоценке риск-ландшафта при изменении конфигурации защищаемой инфраструктуры и статичностью действующих методик, предполагающих разовое обследование по фиксированному профилю соответствия.

КЛЮЧ

Второе противоречие — самое сильное в этой теме и стоит того, чтобы стать центром работы. У ошибки конфигурирования нет CVE, значит нет и вектора CVSS, значит формально нечего складывать в риск. Именно отсюда естественно вырастает «интеллектуальная система» из названия: модель нужна как раз для того, чтобы восстанавливать оценку там, где справочника не существует.

1.4 Задачи, результаты, новизна

Дальше всё идёт четвёрками, строка в строку с противоречиями. Ниже — задачи; результаты, новизна, практическая ценность и теоретическая значимость пишутся такими же четырьмя пунктами, каждый начинается с оборота «в отличие от аналогов» или «впервые получено».

ЧЕРНОВИК ТЕКСТА

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие задачи:

1. организация сбора и суммаризации сведений об ошибках конфигурирования сервисов Linux из открытых источников (CIS Benchmarks, DISA STIG, SCAP-контент, CWE, БДУ ФСТЭК России) с формированием структурированной базы троек «конфигурационный недостаток — эксплуатирующая техника — наступающий ущерб»;
2. разработка методики количественной оценки критичности ошибок конфигурирования, не имеющих CVE-идентификатора, на основе адаптации базовых и контекстных метрик CVSS 4.0 и вероятностных оценок эксплуатации;
3. построение дерева угроз и индуцированных ими рисков и формирование сценариев эксплуатации конфигурационных недостатков в виде последовательностей техник MITRE ATT&CK с расчётом риска успешности каждого сценария;
4. разработка алгоритмического обеспечения интеллектуальной системы, обеспечивающей непрерывную переоценку риск-ландшафта серверной инфраструктуры при изменении её конфигурации.

ЗАПРЕТ

Задача «ознакомиться с...» или «изучить...» запрещена прямым текстом: она решается в первой главе при постановке задач всей работы. Каждая задача — действие с результатом: организация, разработка, построение, формирование.

МЕТОДЫ ИССЛЕДОВАНИЯ

Теория рисков и вероятностное моделирование; теория графов (сценарии как пути в графе достижимости); методы машинного обучения для восстановления оценки критичности; методики ФСТЭК России по оценке угроз; методы экспертных оценок.

02 Раздел 1. Модель объекта защиты

Вот здесь ваши четыре темы принципиально отличаются от работ ИБ-201 и здесь же — ваше преимущество. У них объект — абстрактная АИС, поэтому первая глава начинается сразу с баз данных. У вас объект конкретный, и его сначала надо разложить на активы: без этого дерево угроз строить не из чего, оно повиснет в воздухе.

Таблица 1.1 — Декомпозиция объекта защиты и характерные конфигурационные недостатки

ПОДСИСТЕМА (АКТИВ)	ХАРАКТЕРНЫЙ НЕДОСТАТОК КОНФИГУРАЦИИ	ПАРАМЕТР	НАРУШАЕМОЕ СВОЙСТВО
Удалённый доступ (OpenSSH)	Разрешён вход суперпользователя, включена парольная аутентификация, устаревшие алгоритмы	`PermitRootLogin` `PasswordAuthentication`	Конфиденциальность, целостность
Аутентификация и учётные записи (PAM, shadow, sudoers)	Отсутствие парольной политики, правила `NOPASSWD`, учётные записи без срока действия	`pam_pwquality` `/etc/sudoers`	Конфиденциальность
Файловая система и права доступа	Избыточные биты SUID/SGID, каталоги, доступные на запись всем, небезопасная `umask`	`SUID/SGID` `o+w`	Целостность
Сетевые сервисы (nginx, Apache, СУБД)	Учётные данные по умолчанию, листинг каталогов, служба, слушающая все интерфейсы	`bind-address` `autoindex`	Конфиденциальность
Механизмы изоляции (SELinux, AppArmor)	Режим `permissive` или полное отключение	`SELINUX=`	Целостность
Планировщики (cron, systemd timers)	Сценарии, доступные на запись непривилегированному пользователю	`/etc/cron.d`	Целостность, доступность
Журналирование и аудит (auditd, journald)	Аудит отключён, недостаточная глубина хранения, отсутствие пересылки на внешний сервер	`auditd rules` `SystemMaxUse`	Неотказуемость
Управление пакетами и обновлениями	Отключены автоматические обновления, подключены неподписанные репозитории	`gpgcheck`	Целостность
Средства контейнеризации	Сокет управления, смонтированный внутрь контейнера; запуск от суперпользователя	`docker.sock`	Целостность, конфиденциальность

Таблица делает сразу три вещи: задаёт границы объекта, даёт готовые узлы для дерева угроз и служит источником «конкретности», которой методика требует от практических рекомендаций. Дальше — модель нарушителя по категориям из Методики ФСТЭК и нормативные требования к объекту: приказы ФСТЭК № 17, 21 и 239 в зависимости от того, какую систему вы объявите защищаемой, ГОСТ Р ИСО/МЭК 27005 по менеджменту риска ИБ, ГОСТ Р 56546 по классификации уязвимостей.

СВЕРИТЬ

Номера и годы редакций приказов и ГОСТов, а также все конкретные CVE и статистические показатели проверьте по действующим редакциям перед сдачей — здесь они приведены как ориентиры структуры, а не как выверенная библиография.

03 Раздел 2. Информационное обеспечение

Это тот самый инвариантный кусок, который есть у всех двадцати работ ИБ-201, и именно он у вас четверых рискует совпасть дословно. Развязка — не пересказывать общий набор баз, а показывать **применимость каждой к вашему конкретному объекту**. Для Linux-конфигураций набор источников заметно отличается от сетевого.

Таблица 2.1 — Сравнительный анализ источников сведений применительно к конфигурационным недостаткам

ИСТОЧНИК	ТИП СВЕДЕНИЙ	ПРИМЕНИМОСТЬ К ОБЪЕКТУ	ОГРАНИЧЕНИЕ
CIS Benchmarks for Linux	Требования к конфигурации, профили	**Основной источник** перечня недостатков	Не содержит оценки риска, только «соответствует / не соответствует»
SCAP: XCCDF, OVAL	Машиночитаемые проверки	Основа автоматизированного сбора состояния	Результат бинарный, без веса
DISA STIG	Требования по категориям CAT I–III	Готовая грубая шкала критичности	Шкала экспертная, из трёх градаций
CWE	Классы недостатков	Связывает конфигурацию с классом слабости	Не привязан к конкретному сервису
MITRE ATT&CK	Тактики и техники	Даёт сценарную часть — как недостаток эксплуатируется	Не содержит вероятностей
CAPEC	Шаблоны атак	Верхний уровень сценария	Абстрактнее, чем нужно для конфигураций
CVE / NVD	Уязвимости кода	Только для сопутствующих уязвимостей ПО	**Конфигурационных недостатков не содержит**
БДУ ФСТЭК России	Уязвимости и угрозы	Обязательна как национальный источник; раздел угроз применим напрямую	Раздел уязвимостей ориентирован на код
CISA KEV	Эксплуатируемые в реальности	Подтверждение факта эксплуатации	Только для записей с CVE

Последние три строки — не проходной перечень, а доказательство первого противоречия. Вы прямо в таблице показываете: национальная и международная базы уязвимостей ваш класс недостатков не покрывают. Это и есть «белое пятно», которого методика требует от анализа степени проработанности темы.

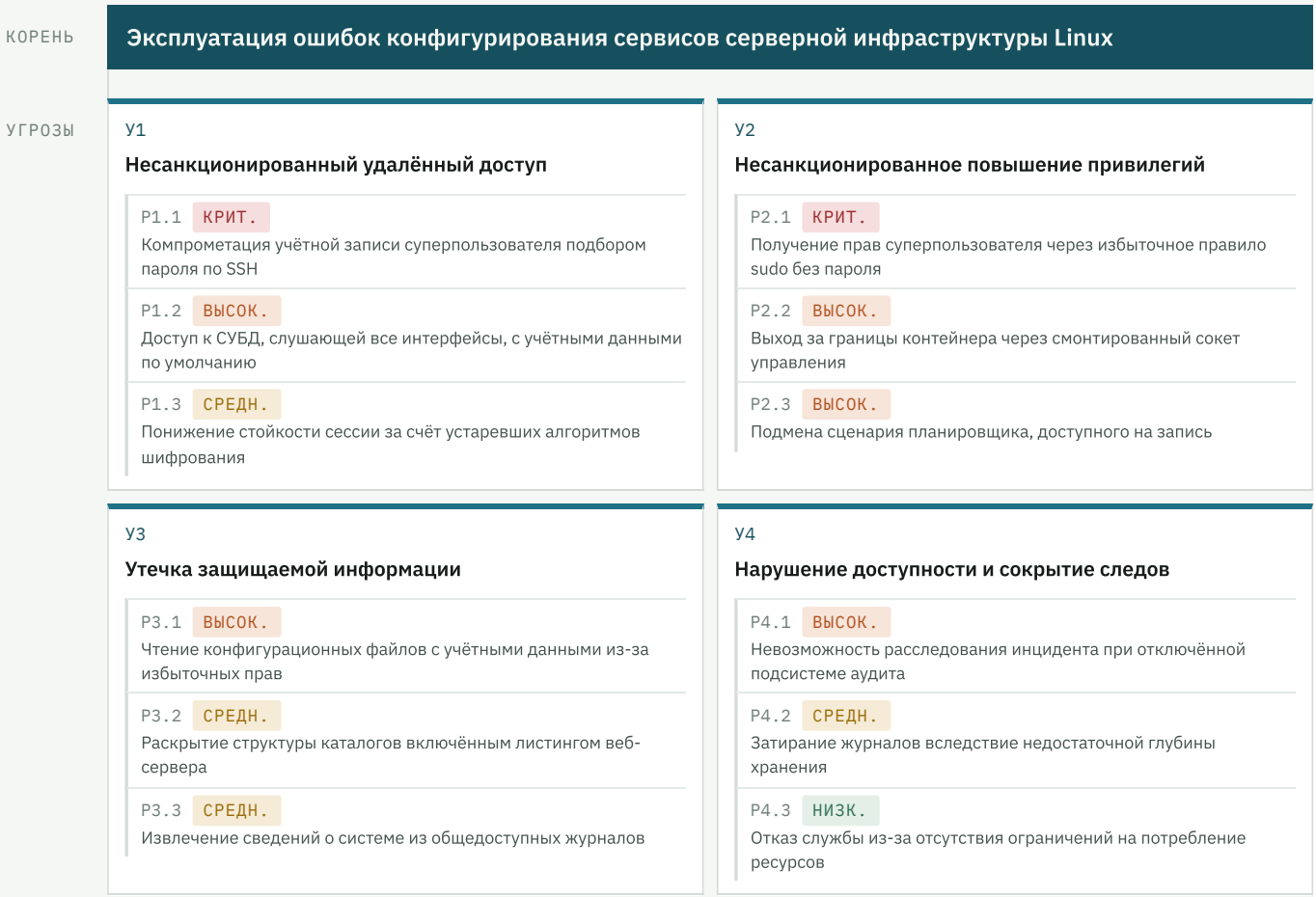
2.2 Инструменты оценки критичности

Здесь второй разворот. Разбираете CVSS 3.1, CVSS 4.0, EPSS и OWASP Risk Rating так же, как это сделано в работах ИБ-201, но приходите к выводу, которого у них нет: **ни один из калькуляторов неприменим к недостатку без CVE напрямую**. EPSS вообще принимает на вход идентификатор уязвимости, CVSS требует вектора, а OWASP RR слишком экспертен и не воспроизводим.

Отсюда — постановка задачи 2: конструирование вектора CVSS 4.0 для конфигурационного недостатка по его SCAP-описанию, и восстановление вероятности эксплуатации моделью, обученной на парах «недостаток — факт эксплуатации» там, где такие пары известны. Это ровно то место, где слово «интеллектуальная» в названии темы перестаёт быть украшением.

04 Раздел 3. Дерево угроз и рисков

Обязательный элемент, без которого работу не примут: пункт первый в списке недопустимого — «отход от схемы: формирование дерева угроз и индуцированных ими рисков». Корень — системообразующая угроза объекту, от неё ветвятся цепочки рисков. Ниже — заполненный фрагмент; в работе его нужно довести до полноты по всем девяти активам из таблицы 1.1.



3.2 Риск-ландшафт

Отдельной подглавой — это прямое указание руководителя из заметок к НИР Косухина. Здесь дерево превращается в числа. Мера риска по терминологии кафедры — **произведение величины ожидаемого ущерба на вероятность его наступления**; используйте эту формулировку дословно, она из определений методики.

Таблица 3.1 — Фрагмент риск-ландшафта объекта защиты

РИСК	ЭКСПЛУАТИРУЕМЫЙ НЕДОСТАТОК	ТЕХНИКА ATT&CK	P	U	R = P·U	УРОВЕНЬ
Р2.1	Правило sudo с NOPASSWD для непривилегированного пользователя	T1548.003	0,74	0,95	0,70	КРИТИЧЕСКИЙ
Р1.1	PermitRootLogin yes при включённой парольной аутентификации	T1110.001	0,68	0,95	0,65	КРИТИЧЕСКИЙ
Р2.2	docker.sock, смонтированный внутрь контейнера	T1611	0,52	0,90	0,47	ВЫСОКИЙ
Р3.1	Конфигурационные файлы с правами чтения для всех	T1552.001	0,61	0,70	0,43	ВЫСОКИЙ
Р4.1	Подсистема аудита отключена	T1562.002	0,45	0,65	0,29	СРЕДНИЙ

P — вероятность успешной эксплуатации, U — нормированная величина ущерба, R — мера риска. Числа в таблице иллюстративные.

Такая таблица закрывает сразу три требования: даёт количественную оценку, показывает связь «недостаток → техника → риск» и служит основой для ранжирования мер противодействия в последней главе диплома. Вокруг неё же строится тепловая карта риск-ландшафта — наглядный материал, который методика прямо требует («слабая иллюстративная база» входит в список недопустимого).

05 Раздел 4. Аналоги и постановка задач

Разбор аналогов пишется последним, когда уже понятно, чего именно им не хватает. Столбец «чего не делает» — это буквально заготовки ваших противоречий.

Таблица 4.1 — Анализ существующих средств

СРЕДСТВО	ЧТО ОБЕСПЕЧИВАЕТ	ЧЕГО НЕ ОБЕСПЕЧИВАЕТ
OpenSCAP / SSG	Проверку соответствия профилю XCCDF, отчёт по несоответствиям	Меры риска; несоответствия равнозначны между собой
Lynis	Эвристический аудит, сводный индекс защищённости	Индекс не является риском и не связан с ущербом
CIS-CAT	Балл соответствия бенчмарку	Оценку вероятности эксплуатации
ScanOVAL для Linux	Поиск уязвимостей ПО по БДУ ФСТЭК России	Работу с конфигурационными недостатками
Wazuh (модуль SCA)	Непрерывный контроль состояния, интеграция с SIEM	Связывание проверок в цепочки, расчёт риска сценария
Средства автоматизации (dev-sec и аналоги)	Приведение конфигурации к заданному состоянию	Оценку — это средство исполнения, а не анализа

Общий вывод, к которому подводит таблица: все существующие средства дают **дискретную оценку соответствия**, не переводят её в меру риска, не учитывают связность недостатков в цепочки и не переоценивают состояние при изменении конфигурации. Четыре пробела — четыре противоречия из раздела 1.3. Круг замкнулся, введение и первая глава смотрят друг на друга.

06 Объёмы и порядок работ

Ориентиры по объёму взяты из фактических работ ИБ-201: у Косухина первая глава заняла 14 страниц, у Есауленко — 24, у Казакова — 11. Сама НИР пишется шире, поскольку из неё потом кроятся две главы.

РАЗДЕЛ	В НИР	В ГЛАВУ 1
Введение	6–8	→ введение ВКР
1. Модель объекта защиты	8–10	6–8
2. Информационное обеспечение	10–12	8–10
3. Дерево угроз и риск-ландшафт	8–10	5–7
4. Аналоги и постановка задач	6–8	4–5
5. Регламенты противодействия *(если потребуют)*	10–14	→ глава 4

Последовательность

Сначала на четверых один раз собирается общий каркас: определения из методики, перечень нормативных документов, сравнительная таблица калькуляторов — как рыба, а не как готовый текст. Дальше каждый в одиночку строит модель своего объекта и дерево угроз: это самая долгая и самая индивидуальная часть, и именно она защищает вас от совпадений. Аналоги и противоречия пишутся в последнюю очередь, когда уже видно, чего существующим средствам не хватает.

Приёмка

- [ ] Дерево угроз и индуцированных рисков построено и находится в первой главе
- [ ] Число противоречий, задач, результатов на защиту, пунктов новизны, теоретической значимости и практической ценности совпадает
- [ ] Предмет исследования сформулирован через оценку и регулирование рисков, цель — через повышение защищённости
- [ ] Определения безопасности, риска, угрозы, ущерба и меры риска приведены дословно по методике кафедры
- [ ] Статистика дана в динамике за несколько лет, присутствуют зарубежные источники
- [ ] Меры риск-управления классифицированы по масштабности и профильности
- [ ] Ни одна задача не начинается со слова «ознакомиться» или «изучить»
- [ ] Список литературы — порядка сотни наименований по ГОСТ, не только русскоязычных, оригинальность не ниже 85 %
- [ ] Иллюстративная база: дерево угроз, тепловая карта риск-ландшафта, схема архитектуры объекта, сравнительные таблицы
- [ ] В списке литературы присутствуют работы Остапенко и выпуски «Информации и безопасности»

07 Перенос на остальные три темы

Каркас общий, меняются объект и профильный источник. Разные фреймворки — не формальность: это то, что разводит четыре работы по содержанию и спасает всех от взаимного плагиата в разделе 2.

Таблица 7.1 — Замены по разделам для остальных тем

РАБОТА	ОБЪЕКТ (РАЗДЕЛ 1)	ПРОФИЛЬНЫЙ ИСТОЧНИК (РАЗДЕЛ 2)	СИСТЕМООБРАЗУЮЩИЕ УГРОЗЫ (РАЗДЕЛ 3)
Полыга Kubernetes	Кластер: плоскость управления, узлы, рабочие нагрузки, реестр образов	ATT&CK for Containers, NIST SP 800-190, CIS Kubernetes Benchmark	Выход за границы контейнера; злоупотребление RBAC; компрометация цепочки образов; доступ к плоскости управления
Ширинкин CI/CD	Конвейер: репозиторий, сборка, артефакты, среда развёртывания, хранилище секретов	OWASP Top 10 CI/CD Security Risks, SLSA, NIST SSDF	Компрометация зависимостей; утечка секретов конвейера; подмена артефакта; злоупотребление правами исполнителя сборки
Ковалев СУД	Каталог учётных записей, служба аутентификации, ролевая модель, привилегированный доступ	ATT&CK (Credential Access, Persistence), NIST SP 800-63, требования к IdM/PAM	Компрометация учётных данных; накопление избыточных прав; обход многофакторной аутентификации; злоупотребление привилегированной записью
Перушкин Linux	Разобран выше как образец		

Общими у всех останутся только CVSS и EPSS в разделе 2.2 — две-три страницы, которые каждый пишет своей рукой. Всё остальное расходится естественным образом, потому что расходятся объекты.

Каркас собран по методической статье Остапенко А. Г. и др. «Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности» («Информация и безопасность», 2020, т. 23, вып. 4) и по фактическим работам выпуска ИБ-201. Формулировки в блоках «черновик текста» — заготовки под правку, а не готовый текст к сдаче.